

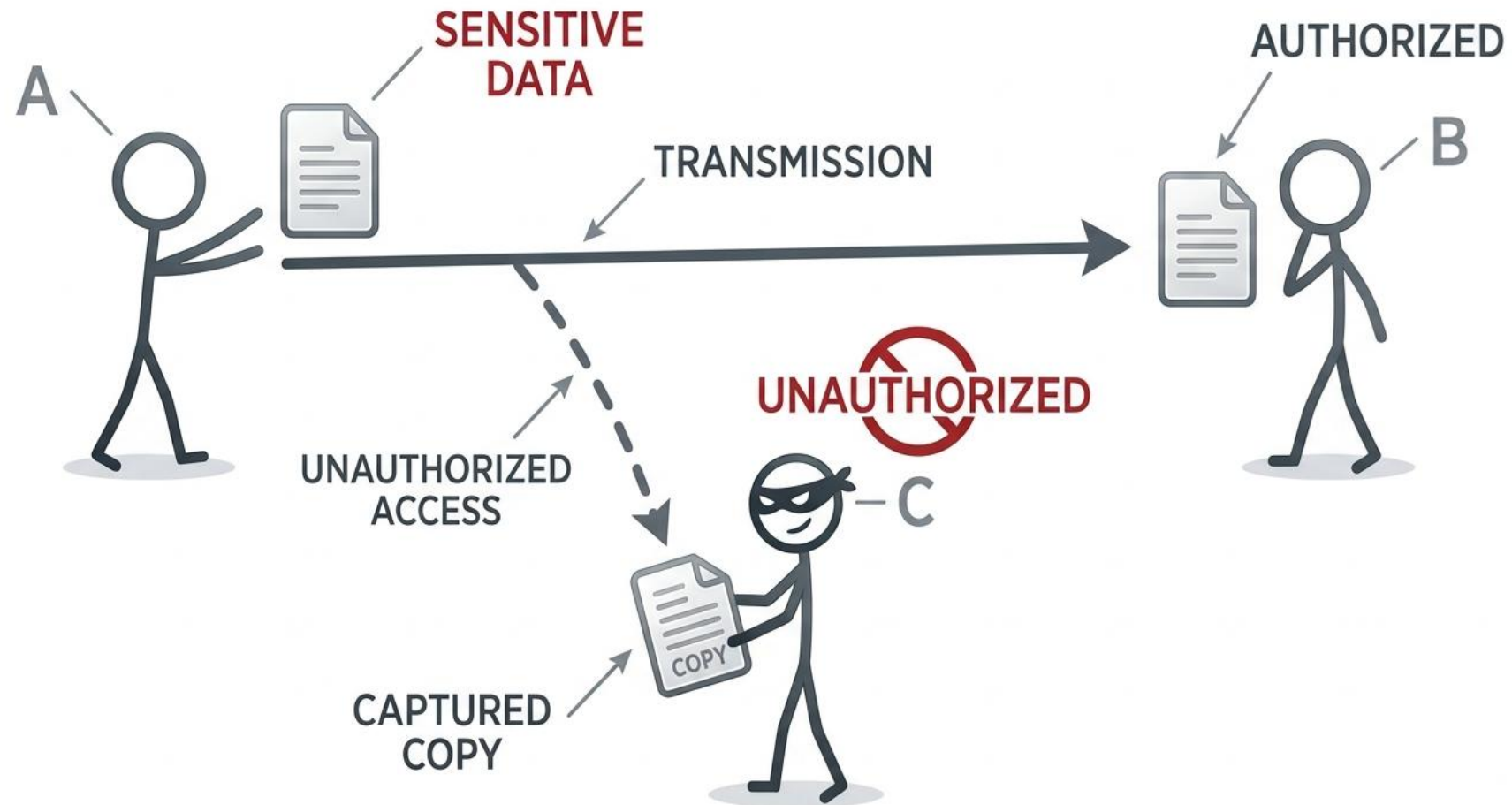
Computer and Network Security Concepts

-Dr. Sumana Maiti

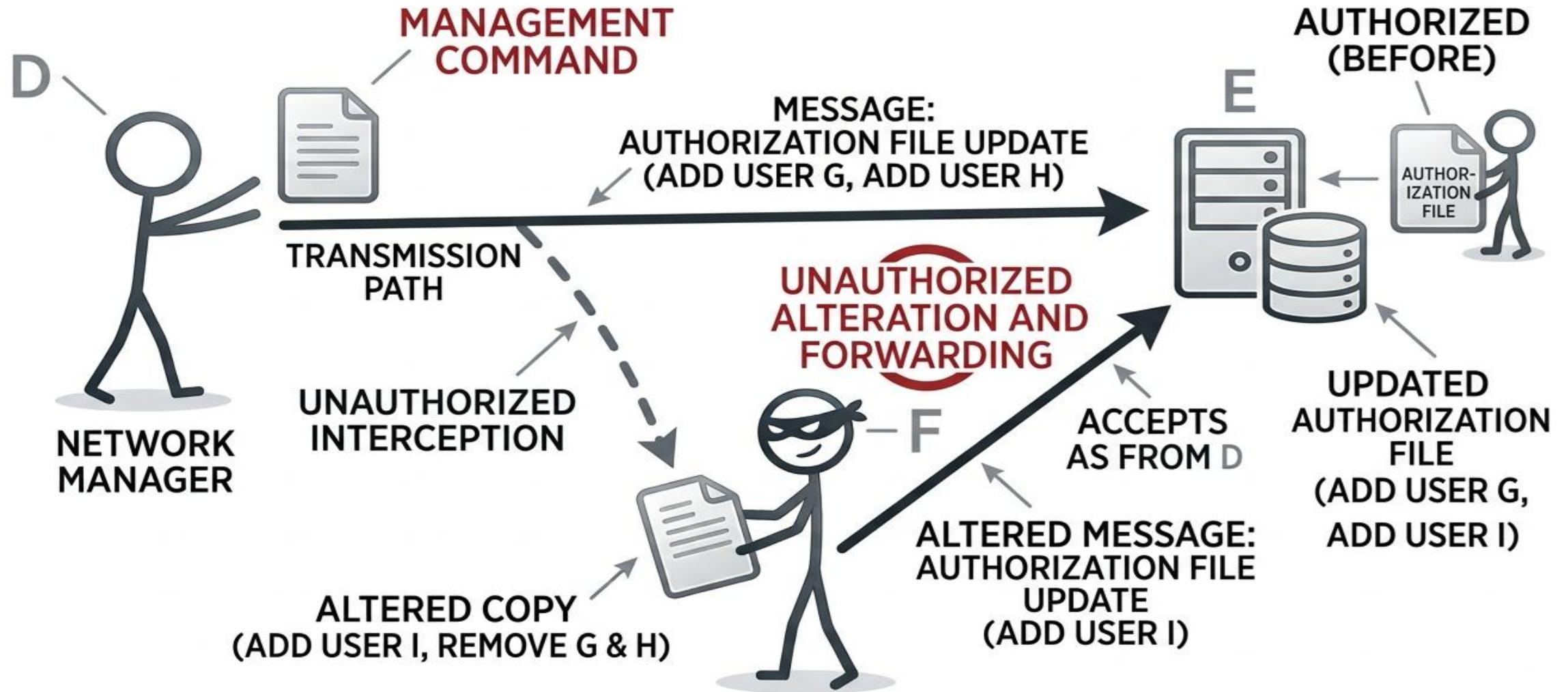
Security Concepts

- The field of network and internet security consists of to prevent, detect, and correct security violations that involve the transmission of information.
- OSI Security refers to a set of protocols, standards, techniques used to ensure the security of data and communications in a network based on OSI model.
- OSI security architecture consists of Security attack, Security mechanism, Security service.

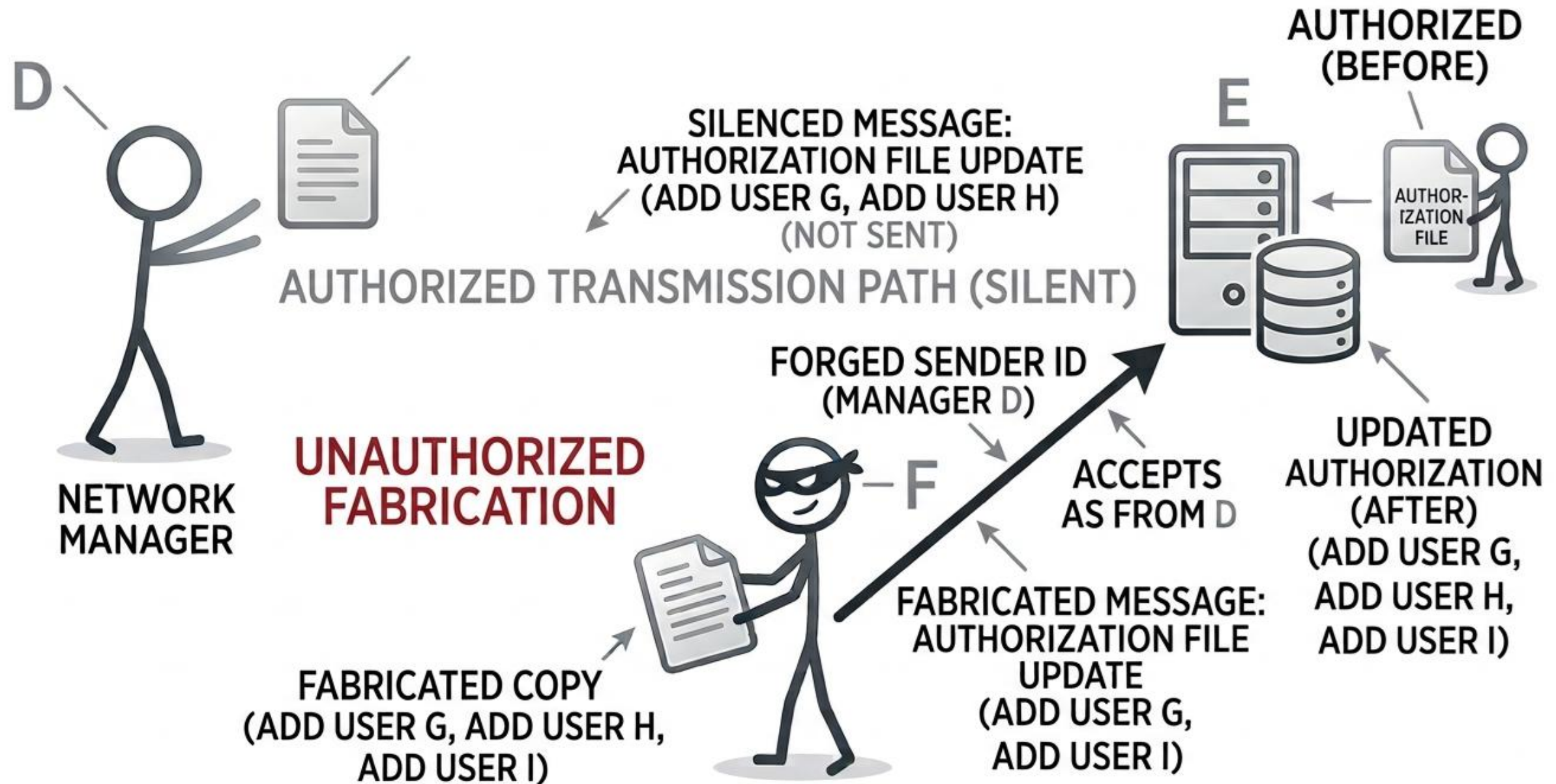
Case 1:



Case 2:

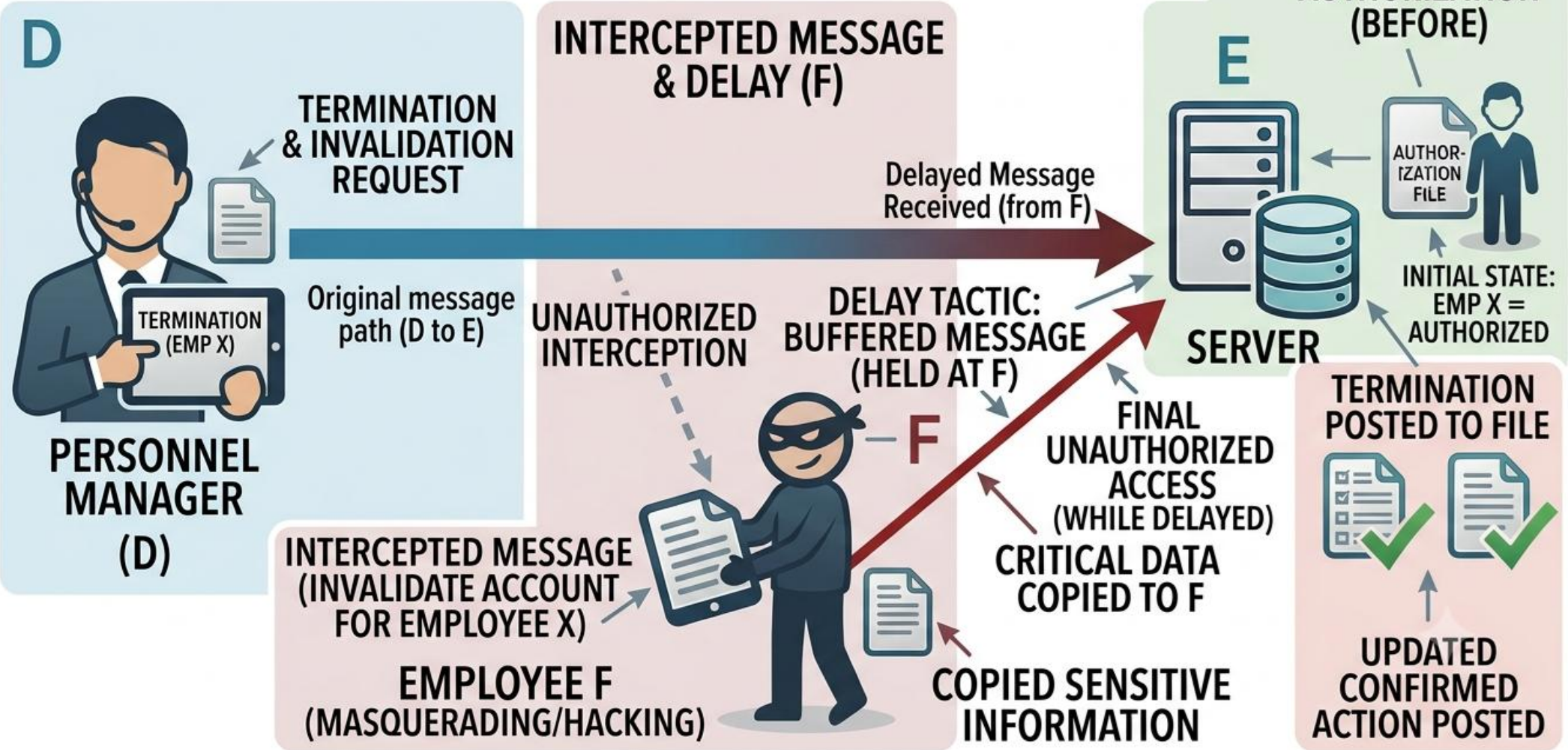


Case 3:



Case 4:

UNAUTHORIZED ACCESS & DELAY: CLARIFIED



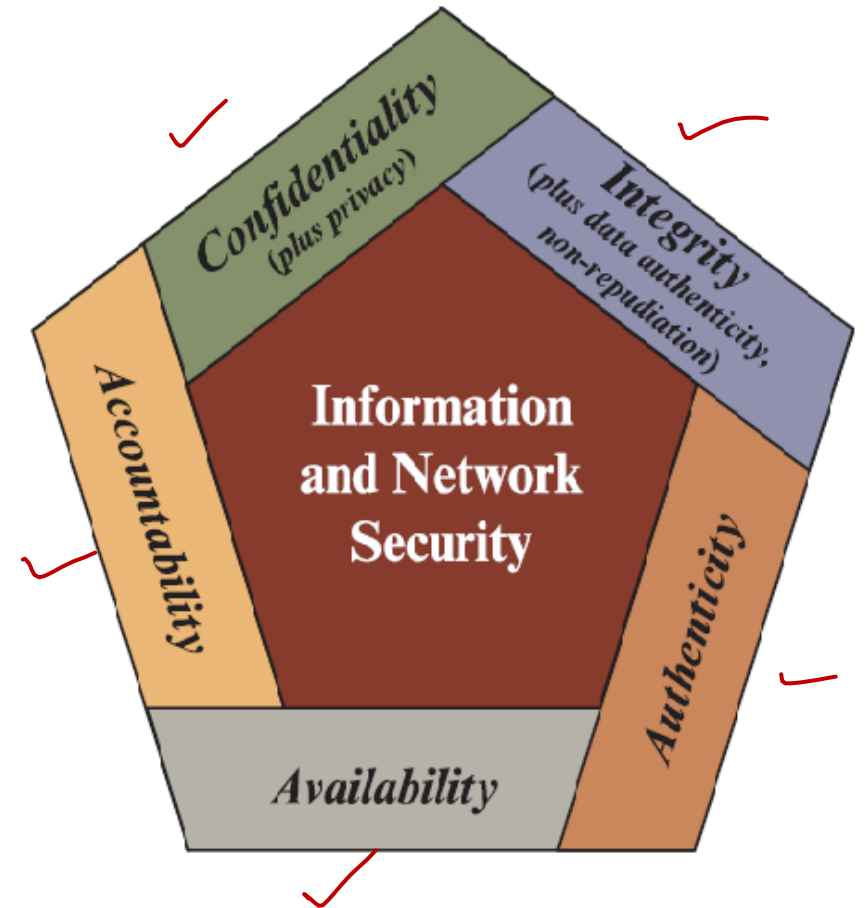
Computer Security Concepts

There are three objectives that are the heart of computer security (**CIA**).

- ✓ Confidentiality
- ✓ Integrity
- ✓ Availability

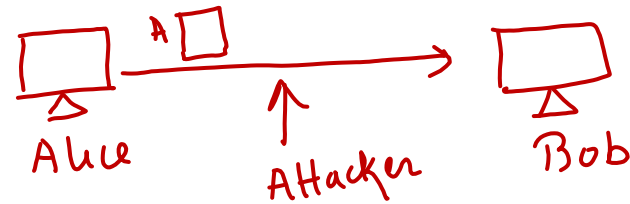
Although the use of CIA triad defines security objectives, there are some additional concepts needed to present a complete picture.

Authentication, Accountability



Confidentiality

- **Data Confidentiality:** It assures that private or confidential information is not made available or disclosed to unauthorized individuals.



- **Privacy:** It assures that individuals can control what information related to them may be collected and stored and by whom and to whom the information may be disclosed.

Integrity

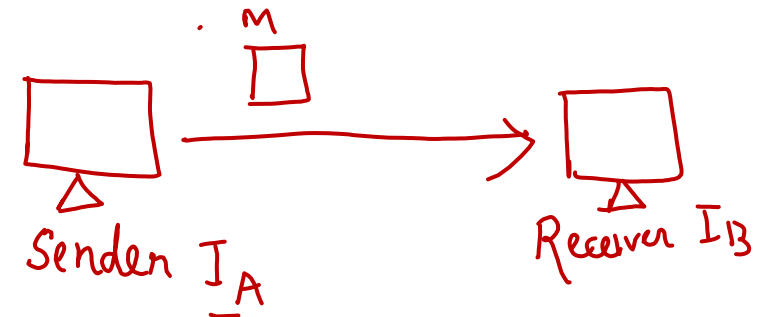
- **Data integrity:** It assures that information (both stored and transmitted) are changed only in a specified and authorized manner.
- **System integrity:** It assures that a system performs its intended function in some desired manner, free from any unauthorized manipulation of the system.

Availability

- Ensuring timely and reliable access to and use of information.
- A loss of availability is the disruption of access to or use of information or an information system.

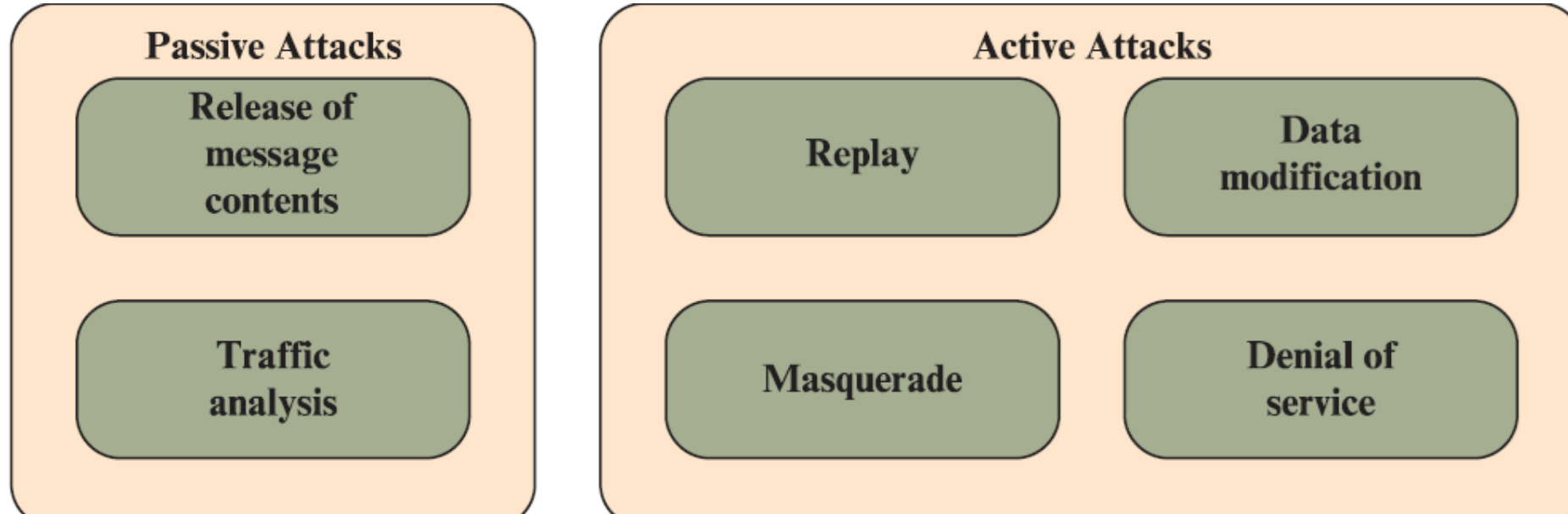
Authentication and Accountability

- **Authentication:** It means verifying that users are who they are and that each input arriving at the system come from a trusted source.
- **Accountability:** It generates the requirement for actions of an entity to be traced uniquely to that entity. It supports nonrepudiation, fault isolation, intrusion detection, prevention, and after action recovery and legal action.



Security Attacks

- **Passive Attack:** It attempts to learn or make use of information from the system, but does not affect system resources.
- **Active Attack:** It attempts to alter system resources or affect their operation.

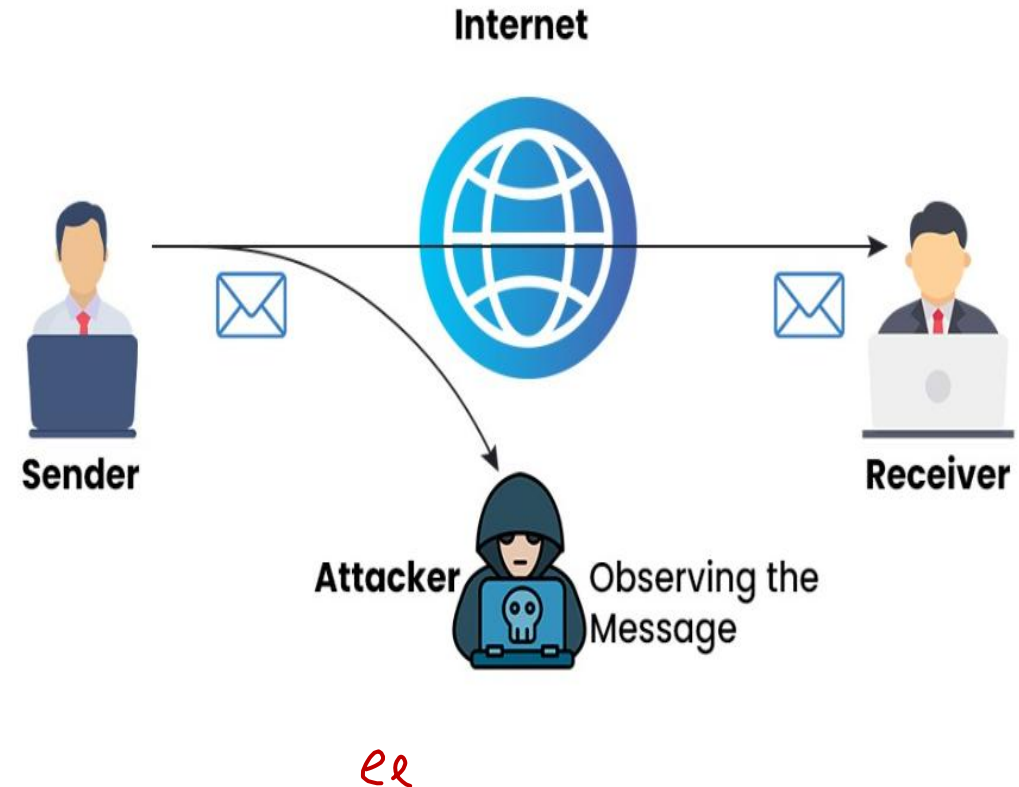


Q1. Define the type of security attack in each of the following cases

- a. A student breaks into a professor's office to obtain a copy of the next day's test.
- b. A student gives a check for \$10 to buy a used book. Later she finds that the check was cashed for \$100.
- c. A student sends hundreds of e-mails per day to another student

Passive Attack

- **Release of message contents:** Prevent an opponent from learning the content of sensitive information
- **Traffic analysis:** Even if the message is encrypted, the opponent can observe the pattern of the message, location, communication hosts, frequency, and length of message



Passive Attack (Continue)

Passive attacks are very difficult to detect, because they do not involve any alteration of data. The message traffic is sent and received in an apparently normal fashion, and neither the sender nor the receiver is aware that a third party has read the message or observed the traffic pattern.

However, it is feasible to prevent the success of these attacks, by encryption. It is better to prevent the passive attack rather than detection.

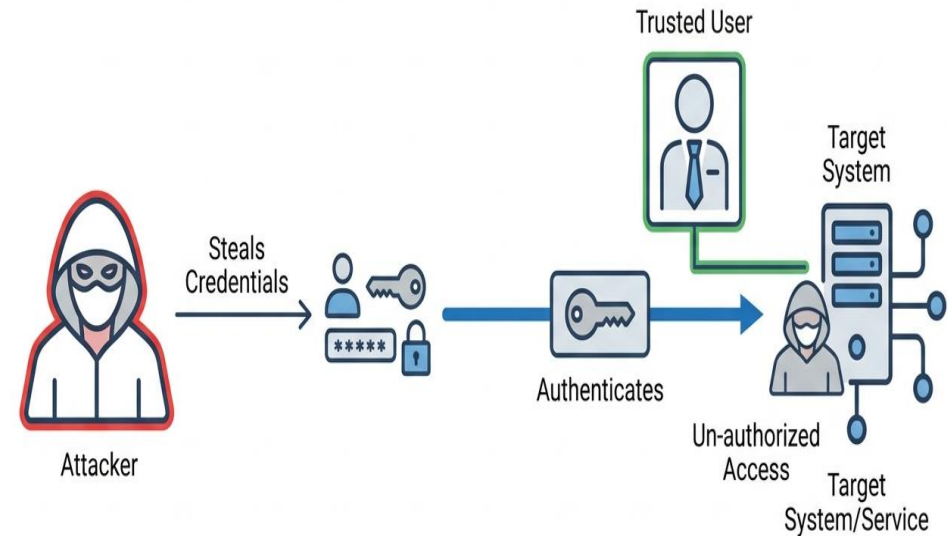
Active Attacks

It involves some modification of data stream or the creation of false stream.

- Masquerade ✓
- Replay ✓
- Modification of message ✓
- Denial of Service ✓

Masquerade

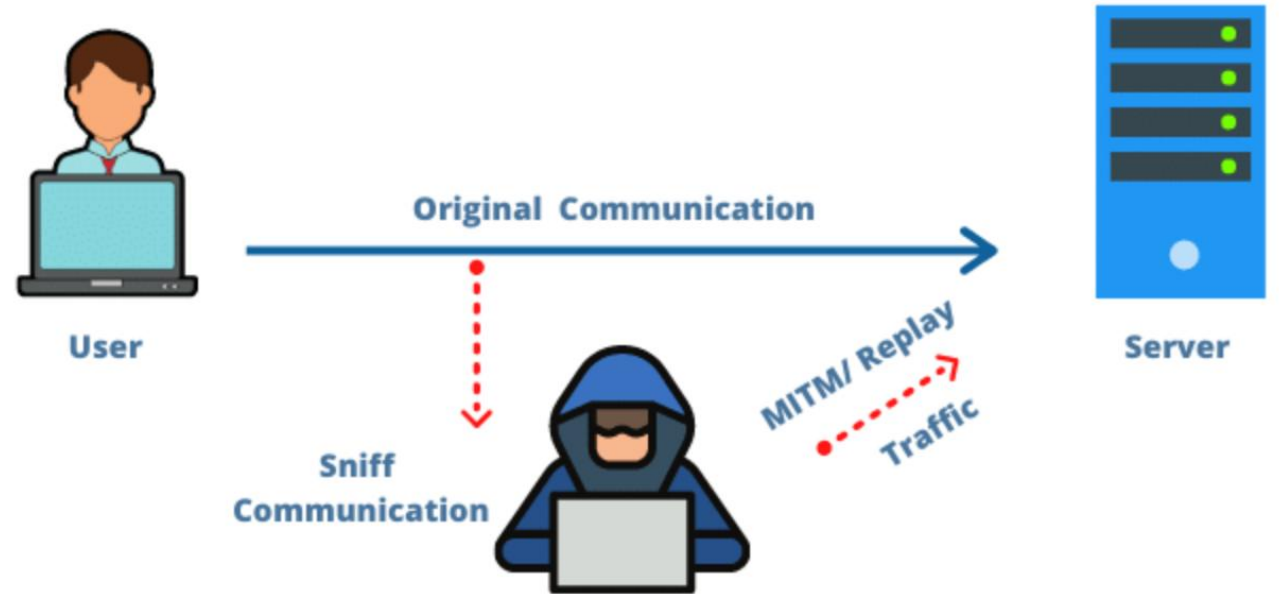
- When an entity pretends to be a different entity.
- A masquerade attack usually include one of the other forms of active attack.
- Attacker uses stolen credentials, spoofed addresses, or forged IDs to gain illegal access to systems or data



Spoofing

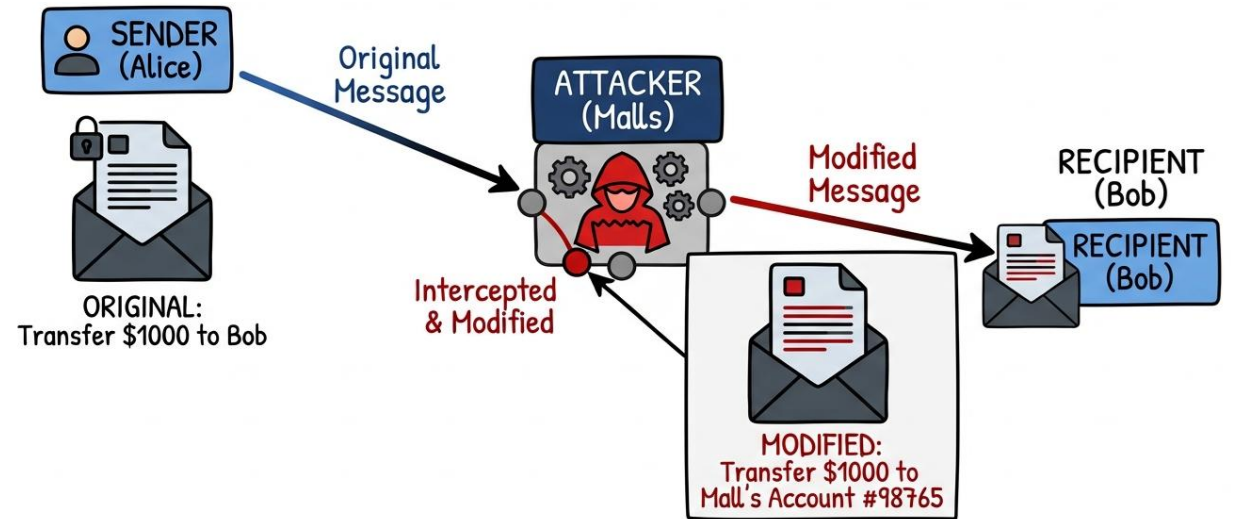
Replay Attack

It involves the passive capture of data unit and its subsequent retransmission to produce an unauthorized effect.



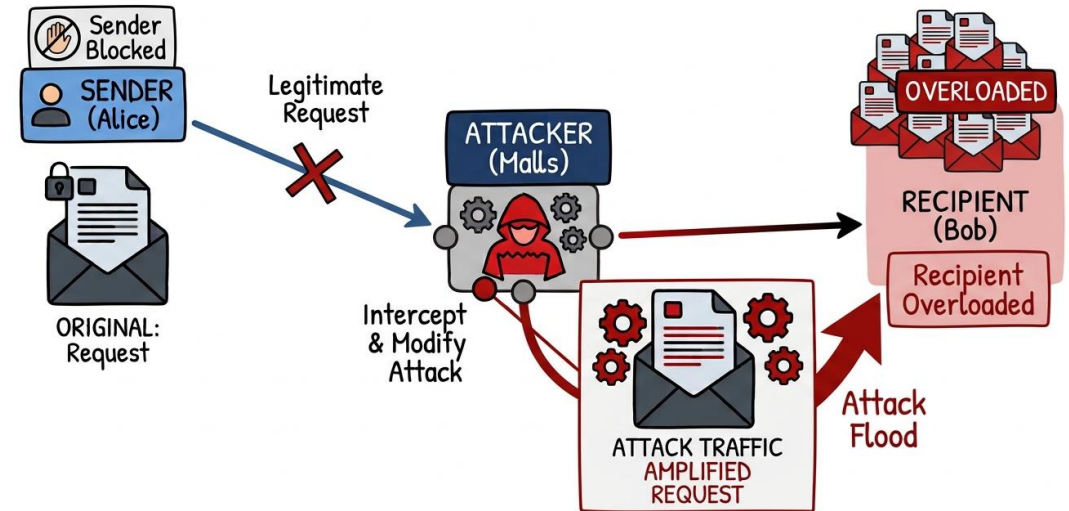
Modification of message

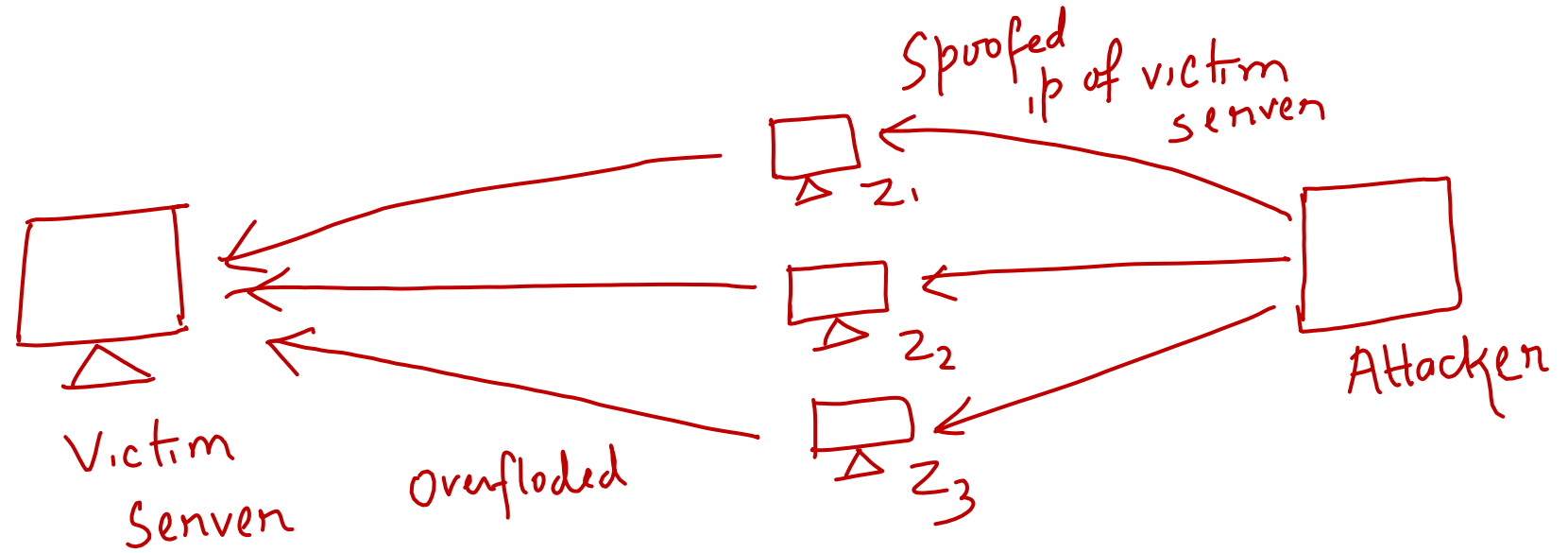
Some portion of a legitimate message is altered, or that messages are delayed or reordered to produce ~~an~~ an unauthorized effect.



Denial of Service

It prevents the normal use of management of communication facilities. This attack may have specific target. An entity may suppress all messages directed to a particular destination.





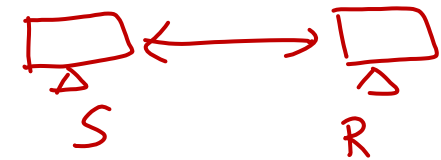
Security Services

The security services are divided into five categories.

1. Authentication
2. Access Control
3. Data Confidentiality
4. Data Integrity
5. Non-repudiation
6. Availability

Authentication

- **Peer entity authentication:** Peer authentication is provided for use at establishment of at times during data transfer phase of connection. It attempts to **provide confidence that entity is not performing either masquerade or an unauthorized replay.**



- **Data origin authentication:** It provides the **validation of the source of a data unit.** It does not provide protection against the duplication or modification of data units. Example: It supports applications like email, where there are no prior interactions between communicating entities.

Access Control

It is the ability to limit and control the access to host systems and applications via communications link.

Example: To achieve this, each entity trying to gain access must first be identified or authenticated.

Attribute-based
encryption

CSE, ITBBS, 18-21

Access
policy

ITBBS, <20

Data Confidentiality

- It is the protection of transmitted data from passive attacks. With respect to the content of data transmission, several levels of protection can be identified.

Data Integrity

Integrity can be applied to a stream of messages, a single message or selected fields within a message.

Non-repudiation

- It prevents either sender or receiver from denying a transmitted message when a message is sent.
- The receiver can prove that the sender sent the message
- Similarly, when a message is received, the sender can prove that the receiver received the message.

Availability

- A system resource should be accessible and usable upon demand by an authorized system entity, according to performance specification for the system.
- A variety of attacks can result in the loss of or reduction in availability.

Security Mechanism

actual message M
Encryption $E()$
Decryption $D()$
Key K

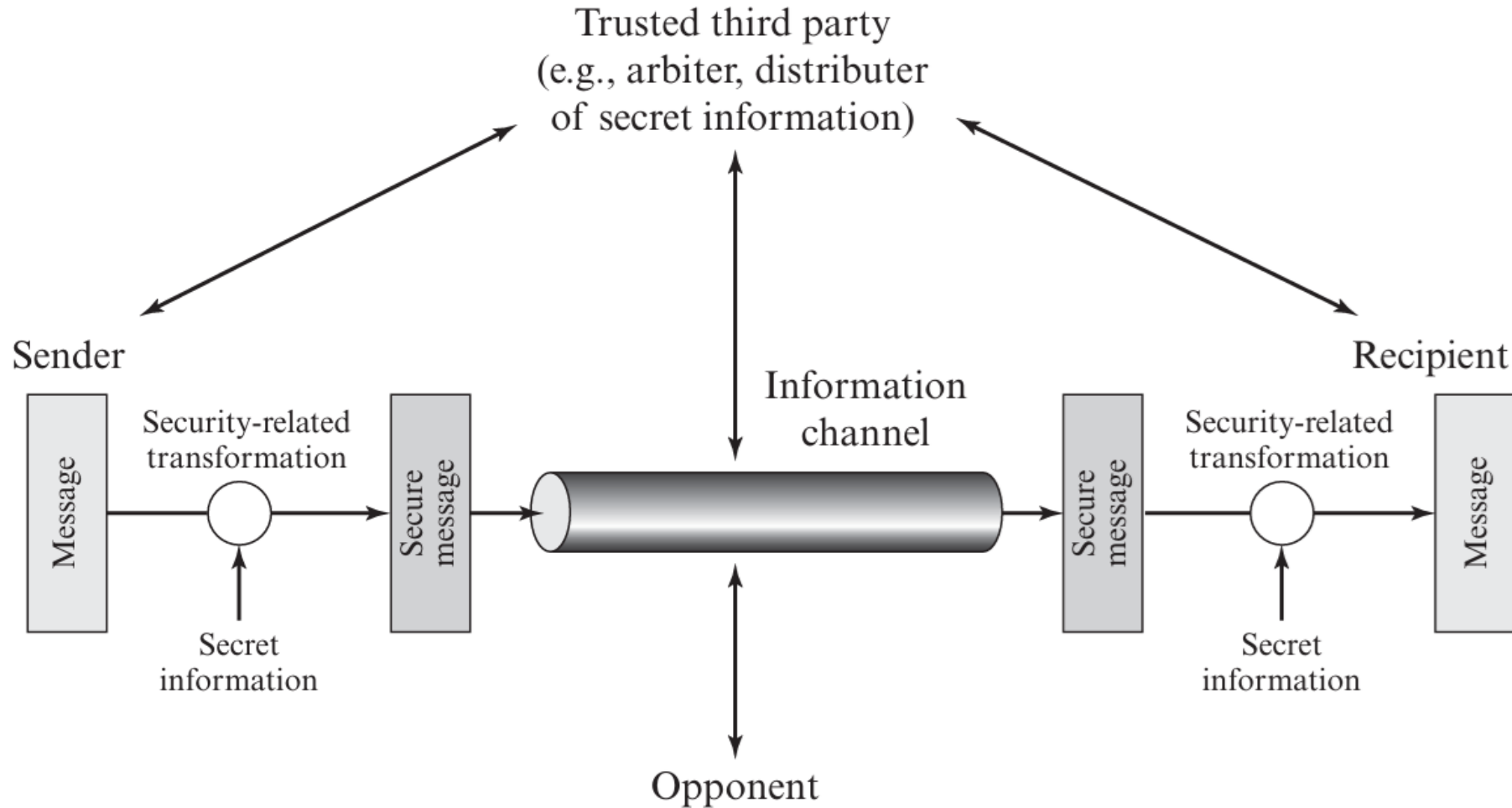
Ciphertext
 $C \leftarrow E(M, K)$
plaintext
 $M \leftarrow D(C, K)$

MECHANISM

SERVICE	Encipherment	Digital signature	Access control	Data integrity	Authentication	Traffic padding	Routing control	Notarization
Peer entity authentication	Y	Y			Y			
Data origin authentication	Y	Y						
Access control			Y					
Confidentiality	Y					Y		
Traffic flow confidentiality	Y				Y	Y		
Data integrity	Y	Y		Y				
Nonrepudiation		Y		Y				Y
Availability				Y	Y			

$Sig(secretKey, M)$

Model for Network Security



Tasks in designing a particular security service

- Design an algorithm for performing the security-related transformation. The algorithm should be such that an opponent cannot defeat its purpose.
- Generate the secret information to be used with the algorithm.
- Develop methods for the distribution and sharing of the secret information.
- Specify a protocol to be used by the two principals that makes use of the security algorithm and the secret information to achieve a particular security service.

Q1. Define the type of security attack in each of the following cases

A. A student breaks into a professor's office to obtain a copy of the next day's test. (Confidentiality)

B. A student gives a check for \$10 to buy a used book. Later she finds that the check was cashed for \$100. (Integrity)

C. A student sends hundreds of e-mails per day to another student
(Availability)

Q2. Consider an automated cash deposit machine in which users provide a card or an account number to deposit cash. Give examples of confidentiality, integrity, and availability requirements associated with the system, and, in each case, indicate the degree of importance of the requirement.

Confidentiality - Card no of one user, Amount, user details

Integrity - Submitted amount, Money should be transferred to actual bank account

Availability

Q3. Consider an **online examination platform**. Identify:

- One major **confidentiality** concern
- One major **integrity** concern
- One major **availability** concern

Then suggest one **security mechanism** for each

Q4. A company encrypts all its internal chat messages but does nothing else. An attacker can still learn a lot by observing the network. What can the attacker infer, and what additional **security mechanisms** (beyond encryption) would you recommend?

Spoofing
Sniffing.

Traffic padding

Authentication and integrity (Digital Signature)

Non-repudiation (Digital Signature)